XTRUSTGUARD: AN EXPLAINABLE AI-BASED ZERO TRUST FRAMEWORK FOR CONTINUOUS RISK ASSESSMENT AND ADAPTIVE ACCESS CONTROL

PROJECT REPORT

Submitted by

PRIYANGA M 2116231901037

in partial fulfillment for the award of the degree of

BACHELOR OF ENGINEERING

in

COMPUTER SCIENCE AND ENGINEERING

(CYBER SECURITY)



RAJALAKSHMI ENGINEERING COLLEGE

ANNA UNIVERSITY: CHENNAI 600 025

OCTOBER 2026

RAJALAKSHMI ENGINEERING COLLEGE

CHENNAI

BONAFIDE CERTIFICATE

Certified that this Project report titled "**XTRUSTGUARD: AN EXPLAINABLE AI-BASED ZERO TRUST FRAMEWORK FOR CONTINUOUS RISK ASSESSMENT AND ADAPTIVE ACCESS CONTROL** " is the bonafide work of "**PRIYANGA M 2116231901037"** who carried out the work under my supervision. Certified further that to the best of my knowledge the work reported herein does not form part of any other project report or dissertation on the basis of which a degree or award was conferred on an earlier occasion on this or any other candidate.

6/10/26

SIGNATURE

Dr. P. Tamilselvi, M.E., Ph.D.,

HEAD OF THE DEPARTMENT

Professor

Department of Computer Science and Engineering (Cyber Security)

Rajalakshmi Engineering College

Chennai – 602 105

V. Subu 6/10/26

SIGNATURE

Dr. Balasubramanian V, M.E., Ph.D.,

SUPERVISOR

Professor

Department of Computer Science and Engineering (Cyber Security)

Rajalakshmi Engineering College

Chennai – 602 105

Submitted to Project Viva-Voce Examination held on 07/10/2026

Internal Examiner

7/10/26

External Examiner

ABSTRACT

The increasing use of cloud computing, remote access, mobile devices, and distributed applications has made traditional perimeter-based security models less effective against modern cyber threats. To address challenges such as compromised credentials, untrusted devices, abnormal user behaviour, and privilege misuse, this project proposes XTrustGuard: An Explainable AI-Based Zero Trust Framework for Continuous Risk Assessment and Adaptive Access Control. The framework integrates Zero Trust principles with Artificial Intelligence and Explainable AI to continuously evaluate users, devices, access contexts, and behavioural information. A hybrid machine learning approach using Isolation Forest for anomaly detection and XGBoost for risk classification is proposed to generate a continuous risk score representing the current security state of a session. SHAP (SHapley Additive exPlanations) is incorporated to identify the important factors influencing risk decisions and improve their transparency. Based on the calculated risk, an Adaptive Policy Engine dynamically determines access levels such as full access, limited access, read-only access, step-up authentication, or session blocking. Continuous monitoring enables the system to detect behavioural changes, recalculate risk, and dynamically update access policies, supporting continuous verification. The framework also considers security controls and threats related to authentication, device trust, behavioural monitoring, machine learning, data protection, audit logging, and privilege misuse.

ACKNOWLEDGEMENT

First, we thank the Almighty God for the successful completion of the project. Our sincere thanks to our Chairman **Mr. S. Meganathan B.E., F.I.E.,** for his sincere endeavor in educating us in his premier institution. We would like to express our deep gratitude to our beloved Chairperson **Dr. Thangam Meganathan Ph.D.,** for her enthusiastic motivation which inspired us a lot in completing this project and Vice Chairman **Mr. Abhay Shankar Meganathan B.E., M.S.,** for providing us with the requisite infrastructure. We also express our sincere gratitude to our college Principal **Dr. S.N. Murugesan M.E., Ph.D.,** and **Dr. P. Tamilselvi M.E., Ph.D., Professor and Head, Department of Computer Science and Engineering (Cyber Security)** and our project guide **Dr. Balasubramanian V, M.E., Ph.D., Professor,** for his encouragement and guiding us throughout the project. We would like to thank our project coordinator **Mr. Benedict J.N., M.E., Assistant Professor (SG),** for his encouragement and guidance towards successful completion of this project and to our parents, friends, all faculty members and supporting staffs for their direct and indirect involvement in successful completion of the project for their encouragement and support.

PRIYANGA M 2116231901037

TABLE OF CONTENTS

CHAPTER NO.	TITLE	PAGE NO.
	ABSTRACT	iii
	LIST OF TABLES	vii
	LIST OF FIGURES	viii
1	**INTRODUCTION**	**1**
	1.1 BACKGROUND	1
	1.2 PROBLEM STATEMENT	2
	1.3 OBJECTIVES	2
	1.4 SCOPE	3
	1.5 SECURITY REQUIREMENTS	4
	1.6 SDG ALIGNMENT	5
2	**LITERATURE REVIEW**	
	2.1 EXISTING SYSTEM WITH SECURITY APPROACHES	6
	2.2 RESEARCH GAPS	8
	2.3 PROPOSED SYSTEM	9
	2.3.1 OVERVIEW OF THE PROPOSED SYSTEM	10
	2.3.2 OBJECTIVES OF THE PROPOSED SYSTEM	12

2.3.3 ADVANTAGES OF THE PROPOSED SYSTEM 14

3 SYSTEM DESIGN

3.1 SYSTEM ARCHITECTURE 16

3.2 MODULE DESIGN 17

3.3 DATA FLOW & UML DIAGRAMS 18

3.4 THREAT MODEL AND ATTACK SURFACE 21

4 SYSTEM DESCRIPTION

4.1 DATA COLLECTION 24

4.2 DATA PREPROCESSING 25

4.2.1 METHODOLOGY 26

4.2.2 RESULTS AND DISCUSSION 27

5 CONCLUSION 30

REFERENCES 31

LIST OF TABLES

TABLE NO.	TITLE	PAGE NO.
1.1	SDG ALIGNMENT GOALS	5
2.1	EXISTING SECURITY APPROACH	6
2.2	RISK-BASED ADAPTIVE ACCESS POLICY	10
4.1	DATA CATEGORIES	24
4.2	DATA PREPROCESSING TECHNIQUES	25
4.3	EVALUATION CATEGORY AND METRICS	27

LIST OF FIGURES

FIGURE	TITLE	PAGE NO.
3.1	SYSTEM ARCHITECTURE OF XTRUSTGUARD	16
3.3	LEVEL 1 DATA FLOW DIAGRAM	17
3.4	USE CASE DIAGRAM	18
3.6	SEQUENCE DIAGRAM	19
3.7	THREAT MODEL AND ATTACK SURFACE	21

CHAPTER 1
INTRODUCTION

1.1 BACKGROUND

The increasing adoption of cloud computing, remote access services, mobile devices, and distributed applications has changed the traditional security environment of modern organizations. Users and devices frequently access organizational resources from different locations and networks, making perimeter-based security models less effective. Traditional approaches generally depend on initial authentication and predefined access privileges. However, a valid user account or authenticated session does not always indicate that the current access request is trustworthy. Compromised credentials, untrusted devices, abnormal user behaviour, and privilege misuse can allow unauthorized activities even after successful authentication.

Zero Trust Architecture addresses these limitations by following the principle of "never trust, always verify." Instead of assuming trust based on network location or previous authentication, Zero Trust continuously evaluates the identity, device, context, and behaviour associated with an access request. This enables organizations to make access decisions based on the current security condition of a user and device.

Artificial Intelligence and Machine Learning can further strengthen Zero Trust by identifying abnormal behavioural patterns and assessing security risks dynamically. Machine learning models can analyse parameters such as failed login attempts, session duration, data transfer, device trust, location, browser characteristics, VPN usage, and unusual activities. However, machine-learning-based security decisions may be difficult for administrators to understand when the reasoning behind a prediction is not visible.

Explainable Artificial Intelligence (XAI) can address this limitation by providing information about the factors contributing to a model's prediction. This improves the interpretability and transparency of automated security decisions. Therefore, integrating

Zero Trust, Machine Learning, and Explainable AI can provide a more adaptive approach to access control.

This project proposes XTrustGuard: An Explainable AI-Based Zero Trust Framework for Continuous Risk Assessment and Adaptive Access Control. The framework combines secure authentication, device and contextual trust assessment, behavioural monitoring, machine-learning-based risk assessment, explainability, and adaptive access policies. The system continuously evaluates the security condition of active sessions and dynamically determines the appropriate level of access.

1.2 PROBLEM STATEMENT

Traditional authentication and access-control mechanisms mainly verify a user's identity at the beginning of a session and then provide access according to predefined permissions. Such approaches may fail to detect changes in user behaviour, compromised devices, abnormal activities, or privilege misuse during an active session.

Existing security solutions may also operate as separate components for authentication, anomaly detection, and access control. In addition, machine-learning-based decisions can be difficult to interpret when administrators cannot determine why a particular user or session was assigned a specific risk level.

Therefore, there is a need for an integrated security framework that continuously evaluates user, device, contextual, and behavioural information; detects anomalous activities; explains machine-learning-based risk decisions; and dynamically adjusts access privileges according to the current security risk.

1.3 OBJECTIVES

The main objectives of the proposed XTrustGuard framework are:

1. To implement secure user authentication and session management using mechanisms such as JWT and bcrypt.
2. To evaluate device and contextual trust using relevant security attributes.
3. To collect and analyse user behavioural information for continuous risk assessment.
4. To use Isolation Forest for detecting anomalous behavioural patterns.
5. To use XGBoost for classifying sessions into different risk levels.
6. To generate a normalized risk score representing the current security condition.
7. To apply SHAP-based explainability to identify important factors influencing risk predictions.
8. To implement an Adaptive Policy Engine that dynamically determines access privileges based on risk.
9. To support continuous session monitoring and reassessment when user behaviour or security context changes.
10. To maintain appropriate security logs and audit information for monitoring and investigation.
11. To evaluate the functional operation of the proposed framework through testing and validation.

1.4 SCOPE

The scope of XTrustGuard covers the design and implementation of a Zero Trust security framework that continuously evaluates access requests and active sessions. The framework focuses on the following areas:

- **Identity and authentication:** Secure user registration, authentication, authorization, and session management.

- **Device and contextual trust:** Evaluation of device, location, browser, VPN, and related contextual attributes.
- **Behavioural monitoring:** Analysis of login patterns, failed login attempts, session duration, resource access, data transfer, and unusual activities.
- **Machine Learning:** Use of Isolation Forest for anomaly detection and XGBoost for risk classification.
- **Explainable AI:** Use of SHAP to identify features contributing to risk predictions.
- **Adaptive access control:** Dynamic access decisions based on the calculated risk level.
- **Continuous monitoring:** Reassessment of session risk when relevant behavioural or contextual information changes.
- **Security monitoring and auditing:** Recording relevant authentication, activity, risk, and access-control events.

1.5 SECURITY REQUIREMENTS / SECURITY CONSIDERATIONS

XTrustGuard is designed with security requirements covering authentication, device trust, behavioural monitoring, machine-learning-based risk assessment, adaptive access control, and auditing.

Authentication and Authorization:
The system should securely authenticate users and ensure that resources are accessed only according to the user's current authorization level. Passwords should be securely protected, and authenticated sessions should use secure token-based mechanisms.

ContinuousVerification:
Authentication should not be treated as permanent trust. User and session conditions should be reassessed when relevant contextual or behavioural changes occur.

Device and Context Trust:

The framework should consider device trust, location, browser characteristics, VPN usage, and other contextual information while determining the security risk of an access request.

Behavioural Monitoring:

User activities should be monitored to identify unusual patterns such as repeated failed logins, abnormal session duration, excessive data transfer, unusual resource access, and other suspicious activities.

Anomaly and Risk Detection:

Machine-learning models should identify anomalous behaviour and classify the current risk level. The resulting risk information should be incorporated into the access-control decision.

Explainability:

The system should provide understandable information about the features influencing machine-learning-based risk predictions. This helps administrators analyse and validate automated decisions.

Adaptive Access Control:

Access privileges should be dynamically adjusted according to the assessed risk. Higher-risk sessions may require additional authentication, restricted access, read-only access, or blocking.

Data Protection and Auditing:

Security-sensitive information should be appropriately protected, while authentication, activity, risk, and policy decisions should be recorded for auditing and incident investigation.

Machine Learning Security:

The reliability of ML-based decisions should be considered against incorrect predictions, manipulated input data, and other potential ML-related security risks.

1.6 SDG ALIGNMENT

Table 1.1: SDG Alignment goals

S. No.	SDG No. & Goal	Relevant SDG Target	Project Contribution / Alignment
1	SDG 9 – Industry, Innovation and Infrastructure	Target 9.5 – Enhance scientific research and technological capabilities	XTrustGuard applies ML, Explainable AI and Zero Trust principles to develop an intelligent cybersecurity framework.
2	SDG 9 – Industry, Innovation and Infrastructure	Target 9.1 – Develop resilient infrastructure	The framework supports digital-system resilience through continuous verification, device trust and adaptive access control.
3	SDG 16 – Peace, Justice and Strong Institutions	Target 16.6 – Develop effective, accountable and transparent institutions	SHAP explanations and audit logs improve transparency and accountability of security decisions.

CHAPTER 2
LITERATURE REVIEW

2.1 EXISTING SYSTEM WITH SECURITY APPROACHES

Traditional cybersecurity systems mainly depend on user authentication and predefined access-control policies. After successful login, permissions are generally assigned according to user roles or predefined rules. However, this approach may not continuously account for changes in user behaviour, device condition, network context, or access patterns during an active session.

The increasing use of cloud computing, remote access, distributed applications, and personal devices has further reduced the effectiveness of traditional network-perimeter security models. Users and devices may access organizational resources from different locations and networks, making permanent trust difficult to establish.

Zero Trust Architecture (ZTA) addresses this limitation through the principle “Never Trust, Always Verify.” Instead of automatically trusting an authenticated user or device, Zero Trust evaluates identity, device posture, context, and risk before granting access. Continuous verification helps reduce the impact of compromised credentials and untrusted devices.

Behavioral analytics provides another layer of security by analysing user activities and identifying deviations from expected behaviour. Parameters such as login time, failed authentication attempts, session duration, resource access, device information, and network context can be used to identify suspicious activities.

Machine Learning can automate this analysis. Isolation Forest can identify unusual observations without requiring every activity to have a predefined label, while

XGBoostcan classify security events when labelled training data is available. However, ML predictions may be difficult for administrators to interpret.

Explainable Artificial Intelligence (XAI) addresses this limitation by providing information about the factors influencing a model prediction. SHAP (SHapley Additive exPlanations) can identify the contribution of individual features to a prediction, improving the transparency of ML-based security analysis.

Adaptive access control further improves security by modifying permissions according to the current security condition. Depending on the assessed risk, a system may allow normal access, restrict privileges, request additional authentication, or block a session.

Therefore, existing approaches provide important capabilities such as Zero Trust verification, behavioural analytics, anomaly detection, risk classification, explainability, and adaptive authorization. XTrustGuard focuses on integrating these capabilities into a single continuously monitored security workflow.

Existing Security Approaches

Table 2.1: Existing Security Approach

Security Approach	**Purpose**	**Limitation / Challenge**
Traditional Authentication	Verifies user identity during login	Does not necessarily provide continuous verification
Role-Based Access Control	Assigns permissions according to predefined roles	Permissions may remain static even when risk changes

Zero Trust Architecture	Continuously verifies users and devices	Requires effective mechanisms for continuous risk evaluation
Behavioral Analytics	Detects deviations from normal user behavior	Requires appropriate behavioral data and feature engineering
Anomaly Detection	Identifies unusual activities	Anomalies do not always directly indicate the level of security risk
Supervised ML Classification	Classifies security events into predefined categories	Requires suitable labeled data
Explainable AI	Provides explanations for ML predictions	Explanation must be connected meaningfully to security decisions
Adaptive Access Control	Changes access according to security conditions	Requires reliable and timely risk assessment
Continuous Monitoring	Re-evaluates security conditions during sessions	Can introduce computational and monitoring overhead

2.2 RESEARCH GAPS

The literature review identifies several areas requiring further investigation in the integration of Zero Trust, behavioural analytics, Machine Learning, Explainable AI, and adaptive access control.

2.2.1 Continuous Risk Assessment

Security conditions can change during an active session. A user who initially behaves normally may later perform suspicious activities. Therefore, there is a need for mechanisms that continuously update session risk using new behavioural and contextual information.

2.2.2 Integration of Anomaly Detection and Risk Classification

Anomaly detection identifies unusual behaviour, whereas supervised classification estimates predefined risk categories. Combining these approaches may provide more comprehensive risk information. XTrustGuard therefore investigates the integration of **Isolation Forest and XGBoost**, with their effectiveness to be established experimentally.

2.2.3 Dynamic Device and Context Trust

Device characteristics, location, browser information, and network conditions can influence the security of an access request. XTrustGuard investigates how these contextual attributes can be incorporated into continuous risk assessment and authorization.

2.2.4 Explainable Machine Learning

Security administrators need to understand why an activity is considered risky. XTrustGuard therefore incorporates **SHAP** to identify important features influencing individual ML predictions.

2.2.5 Explainable Access-Control Decisions

An ML explanation and an access-control decision are related but not identical. The system should establish a clear relationship between the predicted risk, its contributing factors, and the resulting policy action.

2.2.6 Continuous Authorization and Dynamic Privilege Adaptation

Traditional authorization may maintain permissions throughout a session even when the security condition changes. A risk-aware system should be able to modify privileges dynamically, ranging from normal access and restricted access to step-up authentication or session blocking.

2.2.7 Integrated Zero Trust Framework

Existing research provides individual capabilities such as Zero Trust, behavioural analysis, ML-based detection, XAI, and adaptive access control. The integration of these components into a continuously monitored workflow remains an important area for investigation. XTrustGuard addresses this gap by connecting behavioural and device information with ML risk assessment, SHAP explanations, and adaptive authorization.

2.3 PROPOSED SYSTEM

The proposed system is XTrustGuard: An Explainable AI-Based Zero Trust Framework for Continuous Risk Assessment and Adaptive Access Control. XTrustGuard integrates identity verification, device trust, behavioural monitoring, Machine Learning, Explainable AI, continuous risk assessment, and adaptive access control into a unified framework. The framework follows the Zero Trust principle "Never Trust, Always Verify," where successful authentication does not establish permanent trust; instead, user activity, device information, and contextual information are continuously evaluated. Isolation Forest is used for anomaly detection, while XGBoost performs supervised risk classification, with their outputs contributing to a normalized risk score. SHAP is incorporated to explain the factors influencing ML predictions, and the resulting risk assessment is provided to an Adaptive Policy Engine, which determines the appropriate access level. The process continues during an active session so that changes in user behaviour or context can result in updated risk assessments and access decisions.

2.3.1 OVERVIEW OF THE PROPOSED SYSTEM

XTrustGuard consists of the following major components:

1. User Authentication and Identity Management

The system verifies user identity before granting access. The proposed implementation uses **JWT** for authentication and session management and **bcrypt** for password protection. Authentication establishes the initial identity but does not represent permanent trust.

2. Device Trust Assessment

Device and contextual information such as device identity, browser, operating system, IP address, location, and network type can be considered during risk assessment. An unfamiliar device or unusual context may contribute to increased risk.

3. Behavioral Monitoring

User and session activities such as login time, failed login attempts, session duration, resource access, data transfer, and unusual activities are collected for security analysis.

4. Feature Engineering

Raw authentication, device, behavioural, and contextual information is converted into structured features. Preprocessing may include data cleaning, missing-value handling, feature selection, encoding, scaling, and label preparation.

5. Isolation Forest

Isolation Forest acts as the unsupervised anomaly-detection component. It identifies observations that differ significantly from the behavioural patterns represented in the training data. An anomaly is treated as one security signal rather than automatically being classified as malicious.

6. XGBoost Risk Classification

XGBoost is used as the supervised classification component. It learns relationships between security-related features and available risk labels to classify activities into risk categories.

7. Continuous Risk Assessment

The risk engine considers device trust, behavioural information, contextual information, and ML outputs to generate a normalized **0–100 risk score**. The exact weighting mechanism is intended to be validated through experimentation.

8. SHAP Explainability

SHAP provides feature-level explanations for ML predictions. It helps identify the factors contributing to increased or decreased risk and improves the interpretability of automated security decisions.

9. Adaptive Policy Engine

Table 2.2 Risk-Based Adaptive Access Policy

Risk Score	Access Decision
0–25	Full Access
26–45	Limited Access
46–60	Read Only
61–80	Step-Up MFA
81–100	Block Session

2.3.2 OBJECTIVES OF THE PROPOSED SYSTEM

The proposed XTrustGuard framework aims to:

1. Implement continuous Zero Trust verification.
2. Evaluate device and contextual trust.
3. Monitor user behaviour and detect deviations.
4. Detect anomalies using Isolation Forest.
5. Classify risk using XGBoost.
6. Generate a continuous risk score.
7. Explain ML predictions using SHAP.
8. Implement risk-based adaptive access control.
9. Continuously reassess active sessions.
10. Maintain security and audit records.
11. Evaluate the framework using appropriate datasets, baselines, and performance metrics.

2.3.3 ADVANTAGES OF THE PROPOSED SYSTEM

1. Continuous Verification

Authentication is not treated as permanent trust. User and session conditions can be reassessed throughout the session.

2. Behavioral-Aware Security

User activity and behavioural information are incorporated into risk assessment, allowing changes in behaviour to influence security decisions.

3. Device-Aware Risk Assessment

Device and contextual characteristics contribute to the evaluation of access risk.

4. Hybrid Machine Learning

Isolation Forest and XGBoost provide complementary anomaly-detection and risk-classification capabilities. Their combined effectiveness will be established through experimental evaluation.

5. Explainable Security Decisions

SHAP provides feature-level explanations that help administrators understand the factors associated with ML predictions.

6. Adaptive Access Control

The framework supports multiple security responses rather than only allow-or-deny decisions, including restricted access, read-only access, step-up authentication, and session blocking.

7. Dynamic Privilege Management

Access privileges can be adjusted when the security condition changes, supporting continuous authorization.

8. Continuous Monitoring

The feedback loop between user activity, risk assessment, and policy evaluation enables access decisions to be updated as new information becomes available.

9. Improved Auditability

Authentication events, activities, risk assessments, alerts, explanations, and policy decisions can be recorded for security investigation.

CHAPTER 3
SYSTEM DESIGN

3.1 SYSTEM ARCHITECTURE

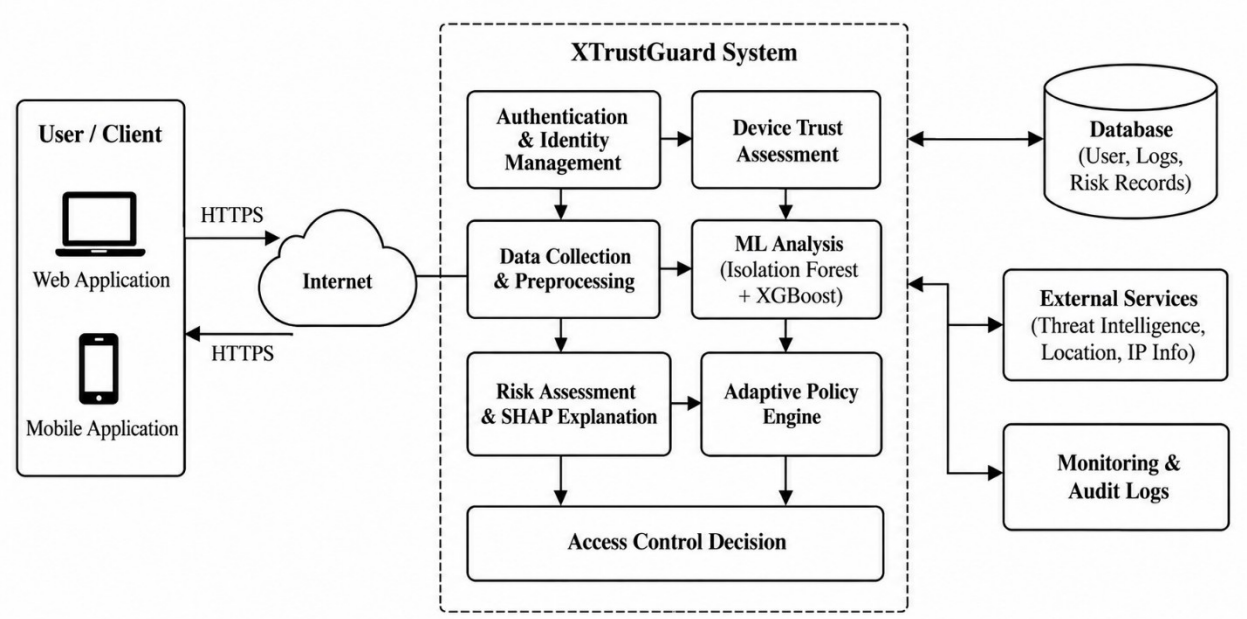


Figure 3.1: System Architecture of XTrustGuard

The major components of the XTrustGuard architecture mentioned in Figure 3.1 are briefly explained below:

1. **User Authentication** – Verifies the user's identity using secure authentication mechanisms before granting access.
2. **Device Trust Assessment** – Evaluates device-related and contextual information to determine the trust level of the accessing device.
3. **Behavioral Data Collection** – Collects user activity and session information such as login attempts, session duration, resource access, and data transfer.
4. **Feature Processing** – Preprocesses and transforms the collected information into suitable features for machine-learning analysis.
5. **Machine Learning Analysis** – Uses Isolation Forest to identify anomalous behaviour and XGBoost to classify the associated risk.

6. **Risk Assessment** – Combines relevant security information and ML outputs to generate a normalized risk score.
7. **Explainability (SHAP)** – Identifies the important features contributing to the ML-based risk prediction.
8. **Adaptive Policy Engine** – Uses the assessed risk level to determine the appropriate access action, such as full access, restricted access, MFA, or blocking.
9. **Database Management** – Stores user information, device details, session data, activities, risk assessments, and security records.
10. **Continuous Monitoring** – Continuously observes active sessions and triggers reassessment when user behaviour or security context changes.

Together, these components form a continuous verify–assess–explain–enforce–monitor workflow for risk-aware access control.

3.2 MODULE DESIGN

Module 1 – Authentication and Identity Management

Handles user registration, login, password protection, JWT-based authentication, and authorization.

Module 2 – Device Trust Assessment

Evaluates device and contextual information to determine the trust level of the accessing device.

Module 3 – Behavioral Monitoring

Collects user and session activities such as failed login attempts, session duration, resource access, and data transfer.

Module 4 – Feature Processing

Cleans, transforms, and prepares the collected data as suitable features for machine-learning analysis.

Module 5 – Anomaly Detection

Uses Isolation Forest to identify unusual or abnormal behavioural patterns.

Module 6 – Risk Classification

Uses XGBoost to classify user activities into different risk categories.

Module 7 – Risk Assessment

Combines behavioural, device, contextual, and ML information to generate an overall risk score.

Module 8 – Explainable AI

Uses SHAP to identify the important features contributing to the ML-based risk prediction.

Module 9 – Adaptive Policy Enforcement

Maps the calculated risk level to an appropriate access decision such as full access, limited access, MFA, or session blocking.

Module 10 – Database and Audit Management

Stores user, device, session, activity, risk assessment, and security-related records for auditing.

Module 11 – Continuous Monitoring

Continuously monitors active sessions and triggers risk reassessment when relevant user behaviour or security conditions change.

These modules work together as an integrated workflow to provide continuous verification, risk assessment, explainable decisions, and adaptive access control.

3.3 DATA FLOW DIAGRAM

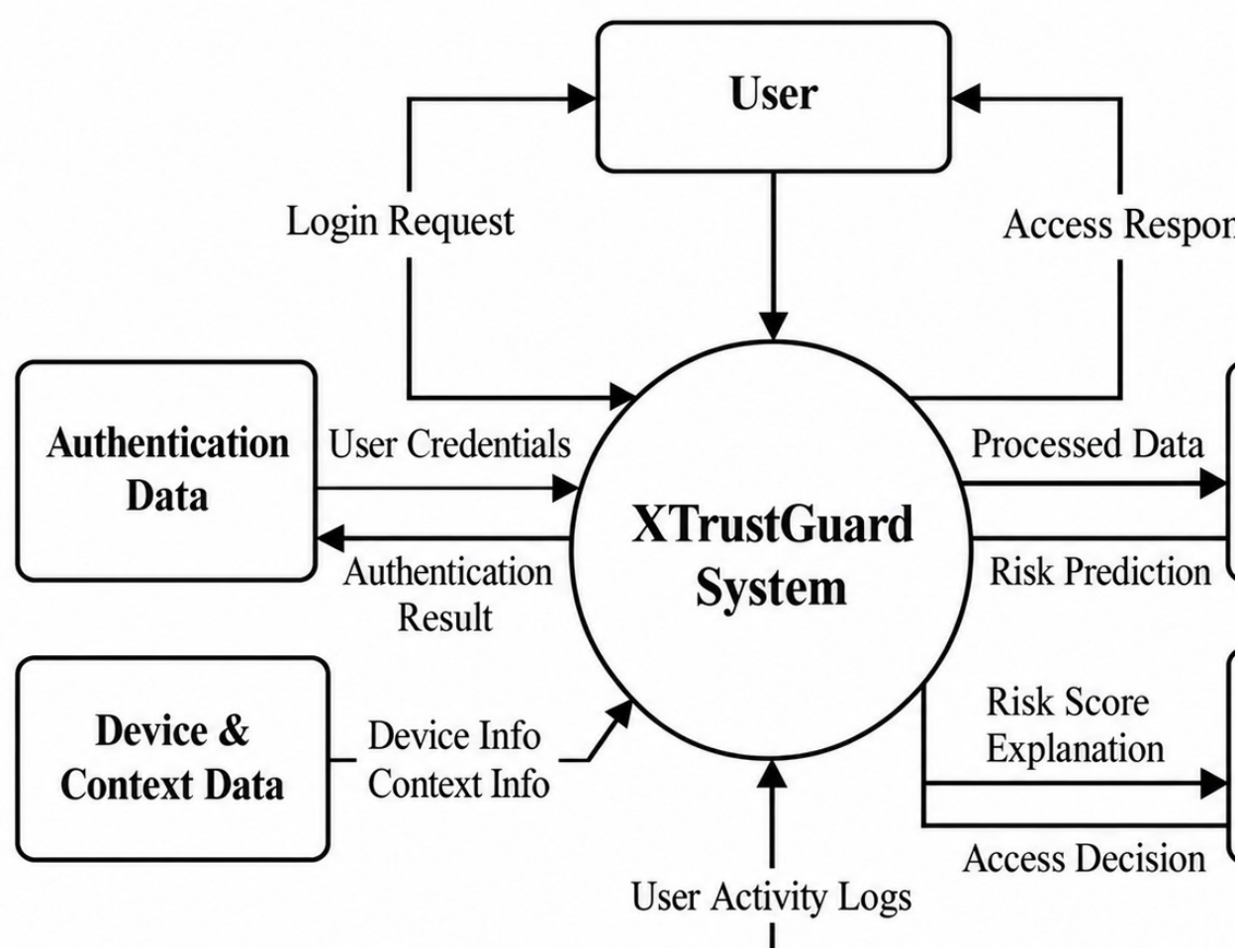


Figure 3.2: Level 1 Data Flow Diagram of XTrustGuard

This diagramFigure 3.2 represents the Level 1 Data Flow of XTrustGuard.

- User initiates a login request and provides credentials to the XTrustGuard system.
- Authentication Data is used to verify the user's identity, and the authentication result is returned.
- Device & Context Data provides information about the device and access context for trust assessment.
- Behavioural Data contains user activity logs that are used for continuous risk analysis.
- The processed data is sent to the ML Models, where Isolation Forest detects anomalies and XGBoost performs risk prediction.

- The resulting risk score and explanation are provided to the Policy Engine, which determines the appropriate access decision.
- The final access response is returned to the user.
- The process supports continuous monitoring, allowing new behavioural or contextual changes to influence subsequent access decisions.

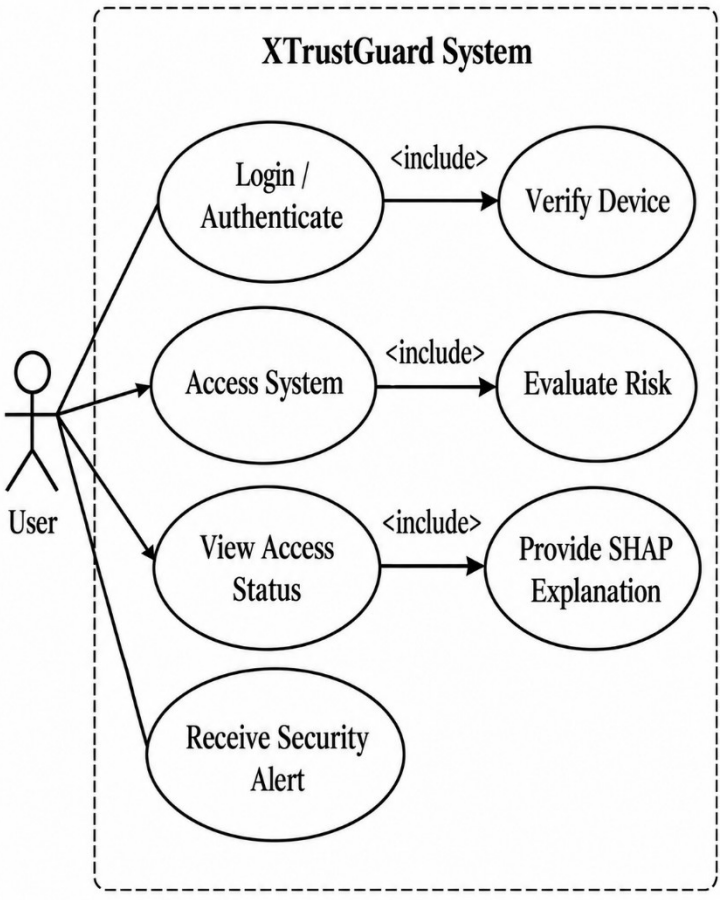


Figure 3.3: Use Case Diagram of XTrustGuard

This Figure3.3 represents how the User interacts with the XTrustGuard System.

- **User** – The main actor who interacts with the system to access protected resources.
- **Login / Authenticate** – The user logs into the system, which includes **Verify Device** to ensure the accessing device is trusted.
- **Access System** – The user requests access to the system, which includes **Evaluate Risk** before granting access.

- **View Access Status** – The user can view the current access status, with **Provide SHAP Explanation** showing the factors influencing the risk decision.
- **Receive Security Alert** – The user receives alerts when security-related events or risks are detected.
- **<<include>> relationships** – Indicate that device verification, risk evaluation, and SHAP explanation are integral parts of the corresponding user actions.

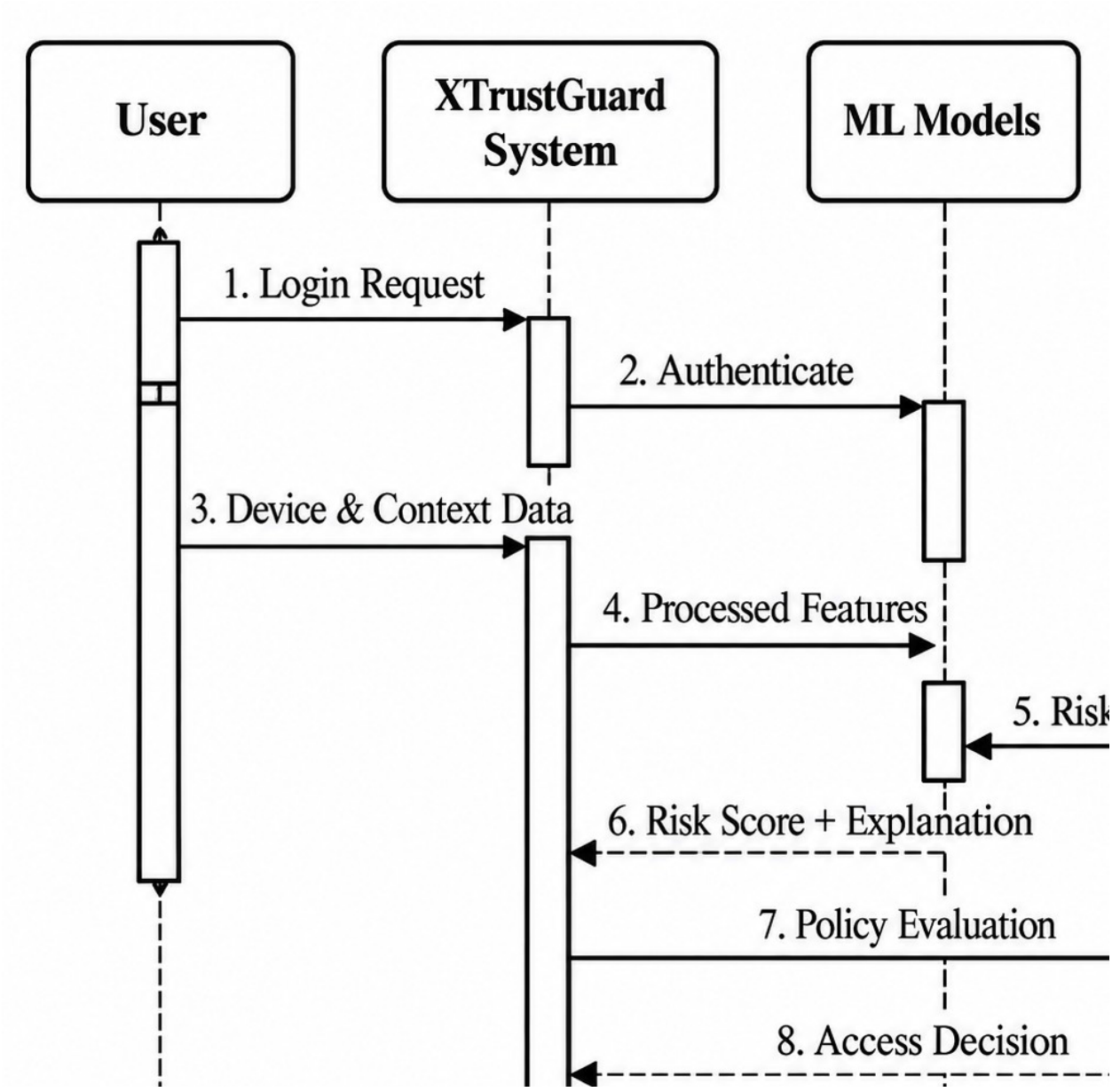


Figure 3.4: Sequence Diagram of XTrustGuard

This Sequence Diagram Figure 3.4 shows the step-by-step interaction between the **User, XTrustGuard System, ML Models, and Policy Engine** during an access request.

1. **Login Request** – The user sends a login request to the XTrustGuard system.
2. **Authenticate** – The system processes the authentication request and verifies the user.
3. **Device & Context Data** – Device and contextual information is provided to the system for trust evaluation.
4. **Processed Features** – The collected information is processed into features and sent to the ML models.
5. **Risk Prediction** – The ML models analyse the features and generate a risk prediction.
6. **Risk Score + Explanation** – The system receives the risk score along with an explanation of the factors influencing the prediction.
7. **Policy Evaluation** – The risk information is passed to the Policy Engine to determine the appropriate access level.
8. **Access Decision** – The Policy Engine returns the access decision to the XTrustGuard system.
9. **Access Response** – The final access response is sent back to the user.

3.4 THREAT MODEL AND ATTACK SURFACE

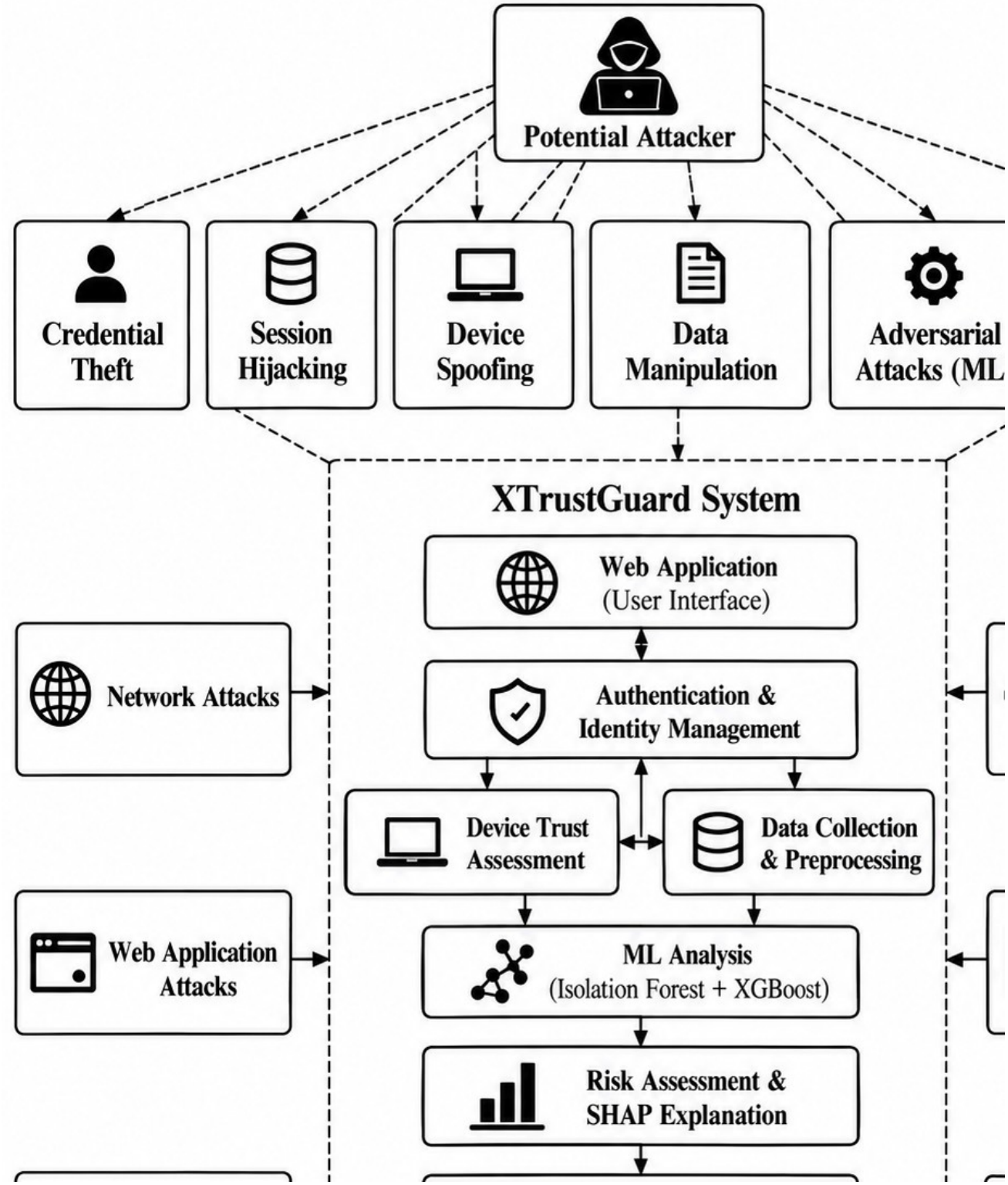


Figure 3.5: Threat Model and Attack Surface of XTrustGuard

XTrustGuard is designed to protect user accounts, sessions, devices, behavioral data, machine-learning components, and access-control decisions. A threat model is therefore required to identify possible attack points and determine the security controls required to protect the system.

Threat Considerations

1. Credential-Based Attacks: Attackers may attempt to obtain or guess legitimate user credentials. Secure password hashing, authentication controls, and failed-login monitoring are therefore required.

2. Session Attacks: An attacker who obtains a valid session token may attempt to access resources without repeating authentication. Secure session handling and token validation are required.

3. Device Spoofing: An attacker may attempt to appear as a trusted device. Device identification and contextual information should therefore be considered during risk assessment.

4. Behavioral Data Manipulation: Incorrect or manipulated behavioral information can affect the ML risk prediction. Input validation and controlled data collection are required.

5. Machine Learning Attacks: The ML pipeline may be affected by poor-quality data, data poisoning, feature manipulation, or data leakage. Dataset validation and appropriate experimental procedures are required.

6. Privilege Escalation: An attacker may attempt to manipulate access-control decisions to obtain higher privileges. The adaptive policy engine should enforce authorization independently of user-provided inputs.

7. Database Attacks: The database contains user, session, activity, risk, and audit information. Unauthorized access or modification could compromise the security of the framework.

8. Log Manipulation: Attackers may attempt to modify or delete security logs to hide malicious activity. Audit information should therefore be protected from unauthorized modification.

The threat model ensures that security is considered not only at the authentication layer but throughout the complete XTrustGuard workflow.

CHAPTER 4
SYSTEM DESCRIPTION

4.1 DATA COLLECTION

XTrustGuard requires user, device, behavioral, and contextual information for continuous risk assessment. The collected information is transformed into features that can be analyzed by the machine-learning models.

The **CERT Insider Threat Dataset** is considered the primary dataset because it provides behavioral information relevant to insider-threat analysis. The dataset can be used to study user activities and identify patterns that differ from expected behavior. Additional datasets such as the LANL Authentication Dataset and UNSW-NB15 may be considered when their features are compatible with the proposed methodology. Synthetic data may be used for attributes that are not available in the selected public datasets.

Data Categories

Table 4.1: Data Categories

Category	**Examples of Data**
User Information	User ID, user role
Authentication	Login time, failed login attempts
Device	Device ID, browser, operating system
Network	IP address, network type
Location	Geographic location / country

Session	Session duration
File Activity	Downloads, uploads
Resource Access	Sensitive-resource access
Behavioral Data	Login hour, day of week, unusual activity
Risk Information	Previous risk score, anomaly information

The collected data is used to construct the feature set required for anomaly detection, risk classification, and continuous risk assessment. During an active session, new activity can be collected periodically so that the current risk can be reassessed.

4.2 DATA PREPROCESSING

Data preprocessing converts the collected information into a consistent format suitable for machine-learning models. The major preprocessing operations include data cleaning, feature selection, categorical encoding, numerical transformation, label preparation, and dataset splitting.

Table 4.2 Data Preprocessing Techniques

Technique	Purpose
Data Cleaning	Removes invalid or inconsistent records
Missing-Value Handling	Handles unavailable feature values
Feature Selection	Selects relevant security features
Categorical Encoding	Converts categorical values into numerical form

Numerical Transformation	Prepares numerical features for ML processing
Label Preparation	Prepares risk labels for supervised learning
Dataset Splitting	Separates data for model development and evaluation

The final processed features are provided to the machine-learning pipeline. Care is taken to avoid data leakage between training and evaluation data.

4.2.1 METHODOLOGY

The XTrustGuard methodology combines anomaly detection, supervised risk classification, explainability, and adaptive access control.

A. Isolation Forest

Isolation Forest is used for unsupervised anomaly detection. It identifies observations that differ from normal behavioural patterns. The resulting anomaly information is used as one of the inputs to the overall risk assessment.

B. XGBoost

XGBoost is used for supervised risk classification. It learns relationships between the selected security features and available risk labels and produces a risk-related prediction.

C. Hybrid Risk Assessment

The risk assessment considers:

- Device and contextual trust
- Behavioural features
- Isolation Forest output
- XGBoost prediction

These inputs are combined to generate a normalized **0–100 risk score**. The exact feature weighting is intended to be validated through experimentation.

D. SHAP Explainability

SHAP is used to explain ML-based prediction by identifying features that contribute to increased or decreased risk. This improves the interpretability of automated security decisions.

E. Adaptive Access Control

The calculated risk score is provided to the Adaptive Policy Engine, which determines the appropriate access level.

F. Continuous Risk Assessment

After an access decision, the active session continues to be monitored. New activity is collected and the relevant features are updated. The ML models then reassess the current risk, generate an explanation, and allow the policy engine to update the access decision when required.

4.2.2 EVALUATION METHODOLOGY

The results section should present the actual experimental outcomes obtained from the implemented XTrustGuard system. Since the final experiments and measured results have not yet been established in the project handover, numerical performance values should not be inserted at this stage.

The evaluation will compare the proposed approach with suitable baselines, including:

1. Rule-based risk assessment
2. Isolation Forest only
3. XGBoost only

4. Proposed Isolation Forest + XGBoost approach

The following metrics can be used:

Table 4.3 Evaluation Category and Metrics

Evaluation Category	**Metrics**
Classification	Accuracy, Precision, Recall, F1-Score
Model Evaluation	ROC-AUC, Confusion Matrix
Security	False Positive Rate, False Negative Rate, Detection Rate
Detection	Detection Time
Access Control	Policy Decision Accuracy, Unauthorized Access Prevention
Explainability	Explanation Consistency, Feature Attribution Stability

Expected Analysis

The experimental analysis should be investigated:

- Whether the hybrid model provides useful risk classification compared with individual models.
- Whether device and behavioral features contribute meaningfully to risk assessment.
- Whether continuous monitoring can detect changes in session risk.
- Whether adaptive policies correctly respond to changing risk.
- Whether SHAP explanations provide understandable information about ML predictions.
- Computational overhead is introduced by continuous risk assessment.

CHAPTER 5
CONCLUSION

XTrustGuard presents an Explainable AI-based Zero Trust framework for continuous risk assessment and adaptive access control. The proposed system moves beyond relying only on initial authentication by continuously considering user behavior, device characteristics, and contextual information during an active session.

The framework integrates Isolation Forest for anomaly detection and XGBoost for risk classification, followed by a risk-assessment mechanism that produces a normalized risk score. SHAP is incorporated to provide explanations for ML-based predictions, while the adaptive policy engine uses the assessed risk to determine appropriate access permissions.

The proposed continuous monitoring mechanism enables the system to reassess session risk when new activities or contextual changes occur. This supports dynamic authorization and allows access permissions to be adjusted according to the current security condition.

The project will be evaluated using suitable datasets, baseline models, performance metrics, and ablation studies. The final experimental results will determine the effectiveness of the proposed approach and the contribution of individual components. The framework also considers important security and practical limitations such as dataset bias, false positives, false negatives, data leakage, concept drift, computational overhead, and deployment challenges.

REFERENCES

1. D. R. Palavali, D. K. Elumalai, and S. Pothireddy, “Behavioral Biometrics for Zero Trust Authentication: A CNN-LSTM Framework for Continuous Authentication,” in 2026 IEEE 16th Annual Computing and Communication Workshop and Conference (CCWC), 2026, pp. 1322–1327.
2. Papastergiou, S., Basheer, N., Lampropoulos, K., Verrios, P., et al., “Explainable AI based dynamic cybersecurity risk management for cyber insurability,” International Journal of Information Security, vol. 25, article 36, 2026.
3. Islam, S., Sardar, B., Kalogeraki, E. M., Lampropoulos, K., et al., “Hybrid AI-Based dynamic risk assessment framework with explainable AI practices for composite product cybersecurity certification,” International Journal of Information Security, vol. 25, article 51, 2026.
4. Gupta, A., Gupta, S., Sharma, S., Singh, J., Ali, F., et al., “A privacy preserving optimized intelligent security framework for smart homes using zero trust architecture and explainability,” Scientific Reports, vol. 16, article 18574, 2026.
5. Alsulami, F. N., “Adaptive-AI-ZeroTrust-Chain: blockchain-backed dynamic zero-trust enforcement via artificial intelligence,” Journal of King Saud University Computer and Information Sciences, vol. 38, article 262, 2026.
6. Abdeljaber, M., et al., “Artificial Intelligence driven fault detection and autonomous recovery in zero trust network architectures,” Discover Artificial Intelligence, 2026.
7. “Zero Trust Architecture Dataset (ZTAD): Advancing AI-driven cybersecurity through multi-source behavioral analysis and feature optimization,” Array, vol. 31, article 100984, 2026.
8. “Resilient Zero-Trust Security Enforcement in Advanced Cloud Service Infrastructures Using Explainable AI for Adaptive Cybersecurity Defense,” in 2025 First International Conference of Advances in Engineering and Computing

Technologies for Sustainable Development (AECTSD), IEEE, 2025. DOI: 10.1109/AECTSD65988.2025.11411402.

9. Islam, S., Basheer, N., Papastergiou, S., Ciampi, M., et al., “Intelligent dynamic cybersecurity risk management framework with explainability and interpretability of AI models for enhancing security and resilience of digital infrastructure,” Journal of Reliable Intelligent Environments, vol. 11, article 12, 2025.
10. “ZenGuard: A machine learning based zero trust framework for context aware threat mitigation using SIEM SOAR and UEBA,” Scientific Reports, 2025.
11. Calzarossa, M. C., Giudici, P., and Zieni, R., “An assessment framework for explainable AI with applications to cybersecurity,” Artificial Intelligence Review, vol. 58, article 150, 2025.
12. Nalinipriya, G., Rama Sree, S., Radhika, K., Lydia, E. L., et al., “Leveraging explainable artificial intelligence for early detection and mitigation of cyber threat in large-scale network environments,” Scientific Reports, vol. 15, article 24662, 2025.
13. Reynaud, S. and Roxin, A., “Review of eXplainable artificial intelligence for cybersecurity systems,” Discover Artificial Intelligence, vol. 5, article 78, 2025.
14. “Trust my IDS: An explainable AI integrated deep learning-based transparent threat detection system for industrial networks,” Computers & Security, vol. 149, article 104191, 2025.
15. “Enhancing cybersecurity risk assessment using temporal knowledge graph-based explainable decision support system,” Decision Support Systems, vol. 198, article 114526, 2025.
16. “An Explainable Artificial Intelligence Framework for Adaptive Zero-Trust Cybersecurity Using Real-Time Threat Intelligence and Deep Learning,” Journal of Intelligent Decision Making and Information Science, 2026.